Authentication & Privileged Access

Week 5 · Care Access Navigator · HealthLine Regional Medical Center (HRMC)

Week 5 deliverables: authentication control baseline, privileged access matrix, service and vendor identity register, and control testing on the live Keycloak lab

Author	Akhila Chennamaneni
Date	November 3, 2026
Version	v1.0
System	Keycloak 26.0 realm care-access-navigator (Docker, localhost) brokered to Microsoft Entra ID
Hardened at	2026-11-03T21:20:55Z (UTC) with can_iam.py harden --migrate and app-gate
Evidence	06_Evidence/04_Test_Results/EV-13_Auth_Hardening_Live_20261103/ (SHA-256 indexed)
Data	Synthetic identities only; no ePHI

Board items covered

Day	Board item	Deliverable in this document	Status
Mon	Document authentication control baseline	Section 1 (10 controls, before/after)	**Done**
Tue	Build privileged access matrix	Section 3 (10 privileged accounts/roles + process)	**Done**
Wed	Define service and vendor identity controls	Section 4 (10 identities + 5 rules)	**Done**
Thu	Test authentication and privileged-access controls	Section 2 (live before/after tests)	**Done**

Result: Audit findings F-01 (MFA), F-02 (lockout) and F-04 (password standard) from the Compliance 1 internal audit CAN-IA-2026-01 were open until this week. They are now fixed on the live lab and verified (corrective actions CA-01, CA-02, CA-04). F-02 and F-04 closed after their 10/23 target date.

1. Authentication control baseline

The baseline states the standard for each authentication control, the value found on the live realm before the change, the value after, and how it was proven. Values come from the can_iam.py audit log, not from memory.

ID	Control and standard	Before	After / verified by	Status
AUTH-01	**MFA for privileged and cardholder-data roles** OTP (TOTP) required for Billing, IT-Support and Security-Analysts at every browser sign-in; users without an authenticator are forced to enrol HIPAA 164.312(d); PCI DSS 8.4.1-8.4.2; NIST 800-53 IA-2(1)	Flow browser-mfa-privileged existed but was bound to nothing; its OTP step only ran for users who had already set up OTP; realm browser flow = browser (F-01)	Realm browser flow = browser-mfa-privileged; condition = realm role mfa-required (held by the 3 privileged groups) *test.billing2 sign-in to billing-app: LOGGED_IN before, MFA_REQUIRED after*	**Enforced**
AUTH-02	**Account lockout (brute-force protection)** Temporary lockout after 10 failures for 30 minutes; failures counted over 12 hours PCI DSS 8.3.4; NIST 800-53 AC-7	bruteForceProtected = false (F-02)	bruteForceProtected = true, failureFactor 10, wait 1800 s *11 wrong passwords on test.vendor1: not locked before; locked after 10 failures after*	**Enforced**
AUTH-03	**Password standard** 12+ characters, upper, lower, digit, special; cannot reuse last 4 PCI DSS 8.3.6-8.3.7; HIPAA 164.308(a)(5)(ii)(D); NIST 800-53 IA-5(1)	length(10), history 3 (F-04)	length(12), history 4 *Admin reset to an 11-character password rejected; reuse of the current password rejected*	**Enforced**
AUTH-04	**Per-application sign-in gate** Only approved job roles may sign in to each app (Billing -> billing-app; Clinician/Nurse -> EHR and Patient Portal; HR/IT-Support -> HR app) HIPAA 164.312(a)(1); PCI DSS 7.2.1; NIST 800-53 AC-3	Any realm user could sign in to any app (scopes only trimmed the token)	4 gate flows bound (gate-<app>); denied users see 'Access denied' *test.clinician2: EHR and Portal LOGGED_IN, Billing and HR DENIED after (EHR, Billing and HR all LOGGED_IN before)*	**Enforced**
AUTH-05	**Group-based role assignment** Access is granted by job-function group, never by a role attached directly to a person HIPAA 164.308(a)(4)(ii)(B); NIST 800-53 AC-2, AC-6	7 local users held a direct role as well as group membership	Direct roles removed from all 7 local users; Entra users keep IdP-mapped roles (by design) *Access review AR-AFTER-HARDEN-20261103: no DIRECT_ROLE_NOT_VIA_GROUP flags on local users*	**Enforced**

ID	Control and standard	Before	After / verified by	Status
AUTH-06	**Session termination on role change and termination** Mover and leaver sign the person out of every session immediately HIPAA 164.308(a)(3)(ii)(C); NIST 800-53 AC-2, AC-12	Manual (Entra 'revoke sessions' only during the JML cycle)	can_iam.py mover / leaver call logout for the user *TC-03 / TC-04 (end-to-end run)*	**Enforced**
AUTH-07	**Authentication and admin event logging** Login and admin events stored with details; 90-day retention in Keycloak HIPAA 164.312(b); PCI DSS 10.2.1; NIST 800-53 AU-2	Events on; no expiry set	eventsExpiration = 7,776,000 s (90 days); admin event details on *Detection run read 146 login and 182 admin events*	Enforced (12-month store: exception EX-02)
AUTH-08	**Federated (Entra ID) users' MFA** Entra users authenticate at Microsoft; MFA must be enforced there (Security defaults, free tier) HIPAA 164.312(d); NIST 800-53 IA-2(1)	Not evidenced	Not evidenced (needs the Entra admin; see EX-01) *Pending: Security defaults screenshot*	Exception EX-01
AUTH-09	**Identity provider transport encryption** TLS 1.2+ for every sign-in HIPAA 164.312(e)(1); PCI DSS 4.2.1	HTTP (Keycloak start-dev) on localhost (F-06)	Unchanged -	Exception EX-05
AUTH-10	**Administrator (master realm) account** Single named admin, MFA, lockout, reachable from localhost only PCI DSS 8.4.1; NIST 800-53 AC-6(5), IA-2(1)	admin without OTP; master realm lockout off; port 8080 published on all interfaces	Unchanged (changing it could lock the only admin out of the lab) *Keycloak master realm extract 11/03*	Exception EX-03

Realm settings before -> after (audit log harden.realm_settings)

```
bruteForceProtected    False                                                                -> True
failureFactor          30                                                                   -> 10
waitIncrementSeconds   60                                                                   -> 1800
maxFailureWaitSeconds  900                                                                  -> 1800
permanentLockout       False                                                                -> False
passwordPolicy         length(10) and upperCase(1) and lowerCase(1) and digits(1) and specialChars(1) and
    passwordHistory(3) -> length(12) and upperCase(1) and lowerCase(1) and digits(1) and specialChars(1) and
    passwordHistory(4)
```

2. Control tests: before and after (Week 5 Day 4)

Two verification identities were created for the test so that no existing account's password had to be changed: **test.billing2** (group Billing, privileged) and **test.clinician2** (group Clinicians). Their password is kept in the lab's local .env file, which is not in git. Each sign-in walks the real browser login flow of the application and reports what Keycloak asked for.

User	Application	Expected after	Before (baseline)	After (hardened)
test.billing2	billing-app	MFA prompt	**LOGGED_IN (auth code issued)**	**MFA_REQUIRED (OTP setup/prompt shown)**
test.billing2	ehr-simulator	Denied	**LOGGED_IN (auth code issued)**	**DENIED (role not approved for this app)**
test.clinician2	billing-app	Denied	**LOGGED_IN (auth code issued)**	**DENIED (role not approved for this app)**
test.clinician2	ehr-simulator	Allowed	**LOGGED_IN (auth code issued)**	**LOGGED_IN (auth code issued)**
test.clinician2	hr-app	Denied	**LOGGED_IN (auth code issued)**	**DENIED (role not approved for this app)**
test.clinician2	patient-portal	Allowed	not run	**LOGGED_IN (auth code issued)**

Test	Before	After
11 wrong passwords on test.vendor1 (lockout)	**FAIL (not locked)**	**PASS (locked after 10 failures)**
Brute-force status after the test	numFailures=0, locked=False	numFailures=10, locked=True

Password policy test (after)	Result
11 characters (below 12 minimum)	**REJECTED: Invalid password: minimum length 12.**
reuse current password (history 4)	**REJECTED: Invalid password: must not be equal to any of last 4 passwords.**

Note: The lockout test unlocks test.vendor1 afterwards (--unlock) so the account is not left locked. The Keycloak events from these tests also produced live detections: CAN-ID-001 brute force, CAN-ID-003 login while locked and CAN-ID-004 unauthorized app access (identity_detections.csv).

What the hardening changed

- MFA flow **browser-mfa-privileged** bound realm-wide and to billing-app, hr-app; the OTP step now depends on realm role **mfa-required**, held by groups Billing, IT-Support and Security-Analysts.
- The hand-built flow had two problems, both fixed: its OTP sub-flow used 'user configured' (people who never set up OTP skipped MFA), and an IT-Support role condition sat outside the sub-flow, where Keycloak ignores it (removed; config {"condUserRole": "it-support"}).

- 7 local users moved from a direct role to their job-function group; 4 Entra users left alone (their role comes from Entra with sync mode FORCE).
- 4 application gates bound: billing-app ← billing; ehr-simulator ← clinician, nurse; patient-portal ← clinician, nurse; hr-app ← hr, it-support.

Rollback

A partial realm export was taken before any change: `03_IAM_Lab/01_Keycloak/02_Realm_Exports/CAN_KC_Realm_Export_Before_W5_Hardening_20261103_v1.json` (client secrets masked by Keycloak). To undo MFA quickly: Authentication → browser → Bind flow (browser).

3. Privileged access matrix (Week 5 Day 2)

Every account or role that can change security settings, read cardholder data or administer a platform used by the project. Billing is treated as privileged because it handles card payments (PCI DSS scope).

ID	Account / role (system)	Holders	MFA	Monitoring	Status
PA-01	**admin (master realm)** Keycloak Full administrator of every realm, user and flow	1: lab administrator (author)	No (EX-03)	Admin events (realm care-access-navigator); CAN-ID-005 on role/group changes	Gap: EX-03
PA-02	**it-support (group IT-Support)** Keycloak / hr-app User support; may sign in to hr-app	test.itsupport1	Yes (enforced 11/03)	CAN-ID-005 High on membership add	Enforced
PA-03	**security-analyst (group Security-Analysts)** Keycloak / SIEM Reads security events and detections; no app access	test.secanalyst1	Yes (enforced 11/03)	CAN-ID-005 High on membership add	Enforced
PA-04	**billing (group Billing)** Keycloak / billing-app (PCI cardholder data) Card payments and patient billing records	test.billing1, test.billing2, Tara Jones (Entra)	Yes (local, enforced 11/03); Entra user: EX-01	CAN-ID-005 High on membership add; CAN-ID-004 on denied apps	Enforced
PA-05	**Global Administrator** Microsoft Entra ID tenant Full tenant administration	1: tenant owner (author)	Verify (Security defaults: EX-01)	Entra audit log (JML-15 export)	Verify
PA-06	**Owner (subscription)** Microsoft Azure Full control of the subscription	1: subscription owner (author)	Through Entra (EX-01)	Azure Activity Log (90 days)	Verify
PA-07	**keycloak (PostgreSQL role)** Keycloak database Database superuser	Service only (no person)	n/a (service)	None (lab)	Rotate: CA-12
PA-08	**it_admin (sudo)** IR lab VM parrot-vm root through sudo	Lab torn down 2026-11-03	n/a	Wazuh rule 100231 (sudo use); IR1-2026-003	Retired with lab
PA-09	**CISO Assistant superuser** CISO Assistant (localhost:8443) GRC tool administrator	1: author	No	None	Low risk (local)
PA-10	**bg-admin-01 (break-glass)** Keycloak master realm Emergency full administrator	Not provisioned	No by design (sealed 24-character password, rotated after each use)	Every sign-in is an incident	Designed only: EX-04

Privileged access lifecycle

Step	Rule
Request	Requester names the privileged role, system, business reason and end date (ticket REQ-)
Approve	Manager approves the need; Security Officer approves the privilege (two approvals)
Assign	IAM Analyst adds the person to the privileged group only (never a direct role); OTP enrolment forced
Monitor	CAN-ID-005 raises High on any membership add to Billing, IT-Support or Security-Analysts
Review / expire	Quarterly access review; privilege removed at end date or on mover/leaver

4. Service and vendor identity register (Week 5 Day 3)

ID	Identity	Owner	Credential / expiry	Status
SV-01	**billing-app** OIDC client (public), Keycloak	Billing application owner	None (public client, browser code flow) *n/a*	OK (enable PKCE: CA-15)
SV-02	**ehr-simulator** OIDC client (public), Keycloak	Clinical application owner	None (public client) *n/a*	OK (enable PKCE: CA-15)
SV-03	**patient-portal** OIDC client (public), Keycloak	Clinical application owner	None (public client) *n/a*	OK (enable PKCE: CA-15)
SV-04	**hr-app** OIDC client (public), Keycloak	HR application owner	None (public client) *n/a*	OK (enable PKCE: CA-15)
SV-05	**admin-cli (used by can_iam.py)** Automation client, Keycloak master realm	IAM Analyst	Admin username + password (password grant) *Rotate with admin password*	Improve: dedicated service account with client credentials (CA-16)
SV-06	**care-access-navigator-keycloak-broker** Entra app registration (OIDC), Microsoft Entra ID	IAM Analyst	Client secret stored in Keycloak identity provider entra-id *Check expiry in Entra (CA-17)*	Verify expiry
SV-07	**keycloak (database)** Database service account, PostgreSQL 16	IT Support	Password in local .env *Rotate (was in public git history: CA-12)*	Rotate
SV-08	**Wazuh agent key (parrot-vm)** Agent enrolment key, Wazuh manager 4.9.2 (IR lab)	Security Analyst	Agent key *Retired 2026-11-03*	Retired
VN-01	**test.vendor1 (Krish)** Vendor workforce account, Keycloak (group Vendors)	Sponsor not recorded	Password *No access_end_date*	Gap: set sponsor + end date or remove (CA-08)
VN-02	**test.vendor2 (Omar Haddad, MedTech Services)** Vendor workforce account, Keycloak (group Vendors)	it.manager1	Password (temporary) *access_end_date 2026-11-02*	Disabled 2026-11-03 (TC-08)

Vendor and service-account rules

- Every vendor account has a named HRMC sponsor, a ticket and an access_end_date no more than 90 days out (can_iam.py refuses a vendor joiner without an end date).
- A signed Business Associate Agreement is on file before any access to systems that hold ePHI (HIPAA 164.308(b)).
- No application access by default: every app gate denies the Vendor role; access is granted per request and time-boxed.

- Access past the end date is flagged High by the access review (ACCESS_PAST_END_DATE) and alerted by CAN-ID-006 if used; the account is disabled with the leaver step.
- Service accounts have an owner, are never used by a person, and their secrets are rotated at least yearly and on any exposure.

5. Exceptions and follow-up actions raised this week

ID	Exception	Compensating controls	Expires
EX-01	Entra-federated users' MFA is enforced in Entra, and that setting is not yet evidenced	Entra assignment required; app roles mapped with sync FORCE; leaver disables both copies	2026-12-15
EX-03	Lab administrator (master realm) has no MFA and the master realm has no lockout	Strong password in a local, untracked .env; realm export before every change; admin events; bind port to localhost (CA-11)	2026-12-31
EX-04	Break-glass account designed but not provisioned	Realm exports allow rebuild; admin password held offline	2027-01-31
EX-05	Keycloak serves sign-in over HTTP (start-dev) (F-06)	No real ePHI; localhost; Azure storage enforces TLS 1.2	2027-01-31

ID	Action	Owner	Due
CA-11	Publish as 127.0.0.1:8080 in docker-compose	IT Support	2026-11-10
CA-12	Rotate Keycloak admin and database passwords	IAM Analyst	2026-11-10
CA-13	Enrolment forced at next sign-in; follow up on accounts not enrolled within 7 days	IAM Analyst	2026-11-10
CA-15	Set pkce.code.challenge.method = S256	IAM Analyst	2026-12-15
CA-16	Create a service-account client with only the realm-management roles can_iam.py needs	IAM Analyst	2027-01-31
CA-17	Record the expiry and set a reminder 30 days before	IAM Analyst	2026-11-10

> **Open items:** Only the account owner can turn on Entra ID Security defaults (EX-01) and sign the access review (CA-05). Both are listed in the corrective-action tracker with steps.